Date: 20/10/2026 **SAI DATTA BHAAVAN MBNP**
241401087 B.Tech CSBS

USER MANAGEMENT AND ROLE-BASED ACCESS CONTROL

AIM

To implement user management and role-based access control (RBAC) in a Zoho Creator application by creating permission sets, a role hierarchy and application users, so that different members of the loan-processing staff get different levels of access to the Loan Application and Pre-screening Management app.

PROCEDURE

1. Background

A loan application contains personal and financial details, so not every employee should be able to see or change every record. Zoho Creator controls this with four related building blocks:

- Permission sets (profiles) – define what a user may do in each form and report: access, view, edit, delete and more.
- Roles – arranged in a hierarchy (CEO → Manager → Officer); a role decides whose records a user can see, because users see the records of the roles below them.
- Data sharing rules – share records from one role or user with another, beyond what the hierarchy gives.
- Users – people invited to the account and then shared into the application with a permission set and a role.

Together these implement the principle of least privilege: every user receives only the access that the job requires and nothing more. This reduces the risk of accidental changes, protects sensitive applicant data and gives the organisation a clear record of who is allowed to do what.

ROLL NO: 241401087

2. Permissions, Roles and Data Sharing Compared

The three mechanisms answer different questions, and the application is secured by combining them rather than using only one.

Mechanism	Question it answers	How it works in Zoho Creator
Permission set	What can this user do?	Per form and report: Access, View, Edit, Delete and More (import, export, bulk actions). Assigned to a user in the Share dialog.
Role	Whose records can this user see?	Roles form a hierarchy; a user sees records created by users in the same role and in roles below it. Set through Reports to.
Data sharing rule	Who else may see these records?	Shares records from a role or user with another role or user at Read Only or higher access, beyond the hierarchy.

3. Access Design

Three levels of access were planned for the loan-processing staff:

Permission set	View	Edit	Delete	Intended use
Loan Officer	Yes	No	No	Enters applications and views them; cannot change or remove records
Loan Manager	Yes	Yes	No	Reviews and corrects applications; cannot delete records
Administrator (account owner)	Yes	Yes	Yes	Full control of the application

Role	Reports to	Description
CEO	– (top role)	Default top role, held by the account owner
Loan Manager	CEO	Reviews and approves loan applications; sees records of officers under this role
Loan Officer	Loan Manager	Handles first-level screening and enters loan applications

ROLL NO. 24140087

4. Creating Permission Sets

- Open the application in edit mode and click Settings → User Permissions (under Permissions).
- On the Permissions tab only the default sets Read and Write exist. Click Add Permission.
- Create Loan Officer: description “Can view and add loan applications but cannot edit or delete.” In the table of modules, tick Access and View for Loan_Application_Form and Access for the dashboard page; leave Edit, Delete and More empty. Save.
- Create Loan Manager: description “Can view, add and edit loan applications but cannot delete.” Tick Access, View and Edit for the form (the View and Edit cells apply to all 3 reports) and Access for the dashboard page; leave Delete and More empty. Save.

5. Creating Roles

- Open the Roles tab. The default top role is CEO.
- Click Add Role. Enter the name Loan Manager, set Reports to = CEO, add a description and Save.
- Click Add Role again. Enter Loan Officer, set Reports to = Loan Manager and Save.
- Use Expand All to confirm the hierarchy CEO → Loan Manager → Loan Officer.

6. Data Sharing Rules

The Data Sharing tab lets the administrator share records created by one role or user with another role or user at a chosen access level (Read Only or more). A rule named Officer Review Queue was started on Loan_Application_Form, with Read Only access. In this trial session the role list in the “Records shared from” box did not load, so the rule could not be saved and the tab still shows “You have not added any data sharing rules yet”. Visibility in the application therefore follows the role hierarchy alone.

7. Adding a User

- A user must first exist in the Creator account. Open the Creator home page → Users and invite the person by e-mail; the status stays “Invited” until the invitation is accepted.
- Back in the application click Share, choose the invited user, and set Assign as = User and the Permission.
- Click Share. The user’s detail panel under Users then lists the application together with the Role and Permission assigned. The e-mail address in the screenshots has been blurred for privacy.

8. Verification Plan

Once the invited user accepts the invitation, access control is verified by signing in as that user and checking each row of the table below against what the application actually allows. Comparing observed behaviour with the expected behaviour shows whether the permission set and role were configured correctly.

Check	Loan Officer expected	Loan Manager expected
Open Loan_Application_Form and submit a record	Allowed	Allowed
View records in the report	Allowed	Allowed
Edit an existing record	Not allowed (no Edit option)	Allowed
Delete a record	Not allowed	Not allowed
See records of the role below	Own records only	Own and Loan Officer records

ROLL NO: 241401087

9. Good Practices Followed

- Separate permission sets were created instead of using the broad default Write set, which gives write permission on all components.
- Delete was withheld from both custom sets, so only the administrator can remove applicant records.
- Roles mirror the real reporting line of the loan team (CEO, Loan Manager, Loan Officer), so record visibility follows responsibility.
- Personal e-mail addresses were blurred in the screenshots so that no private data is published with the report.

10. Observations

- A user cannot be shared into the application until the person has been invited to the Creator account; the status remains “Invited” until the invitation is accepted.
- Permission sets and roles are independent. A user’s Role and Permission are shown side by side in the user’s detail panel and can be changed separately.
- In the permission table the View and Edit cells of a form summarise all the reports based on that form (shown as “3 Reports”), so one tick covers every report of the form.
- The data sharing dialog needs the role list to load before a rule can be saved; this failed in the trial session, so the hierarchy alone controlled visibility.

OUTPUT

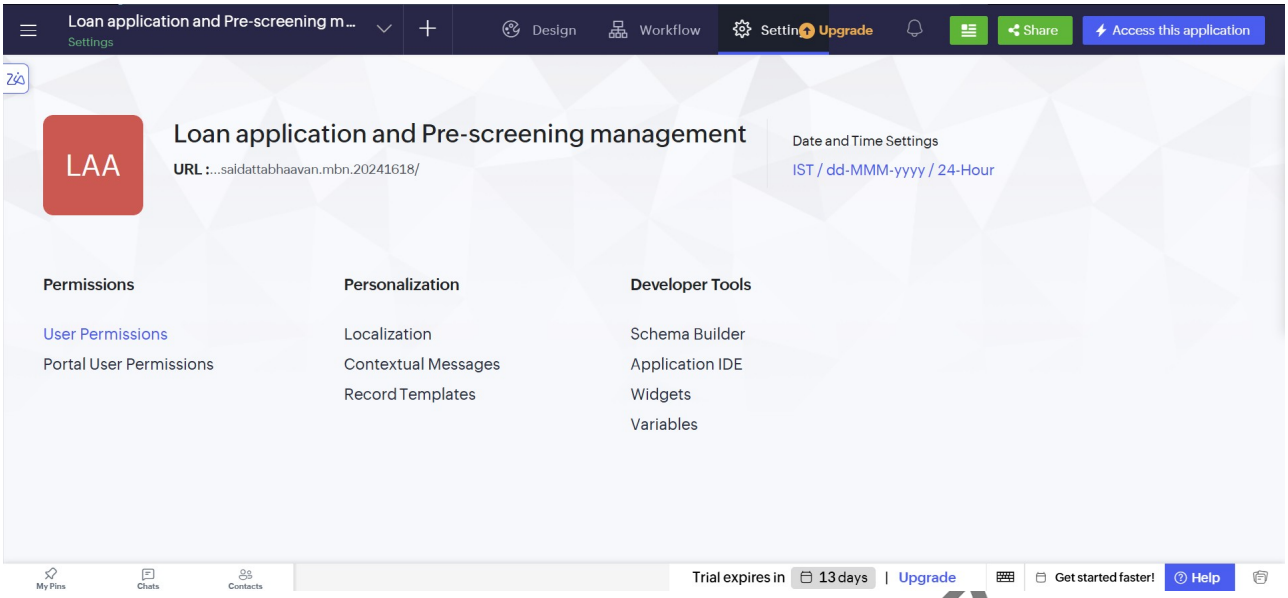


Fig. 1: Application Settings – Permissions → User Permissions

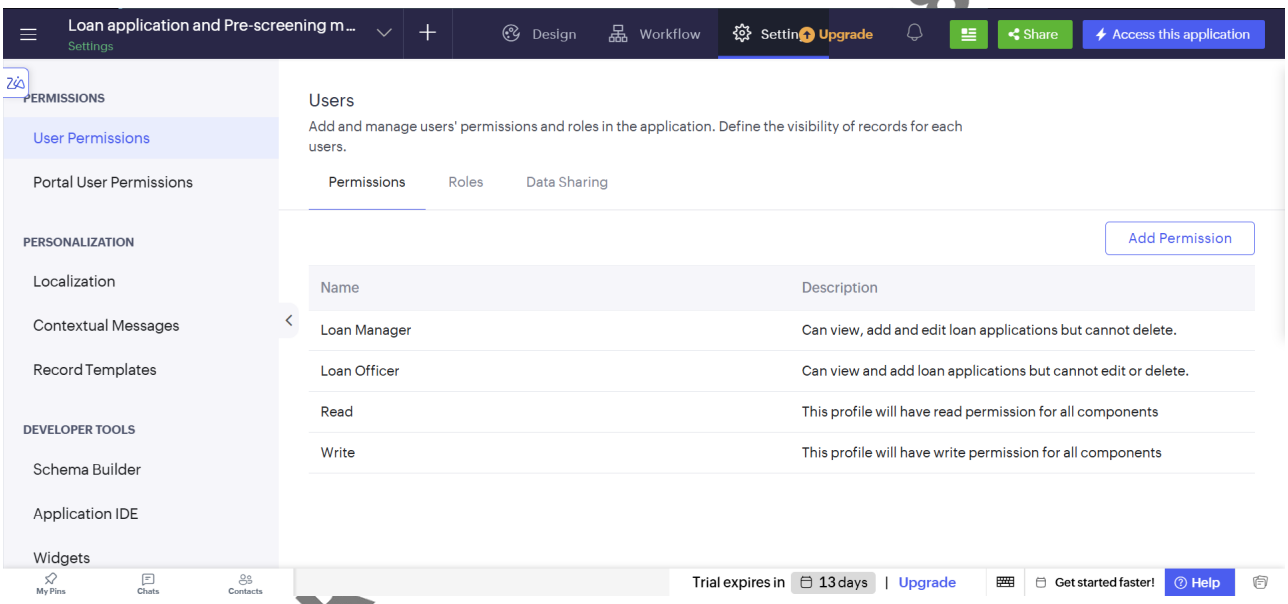


Fig. 2: Permissions tab listing the new Loan Manager and Loan Officer sets with the defaults Read and Write

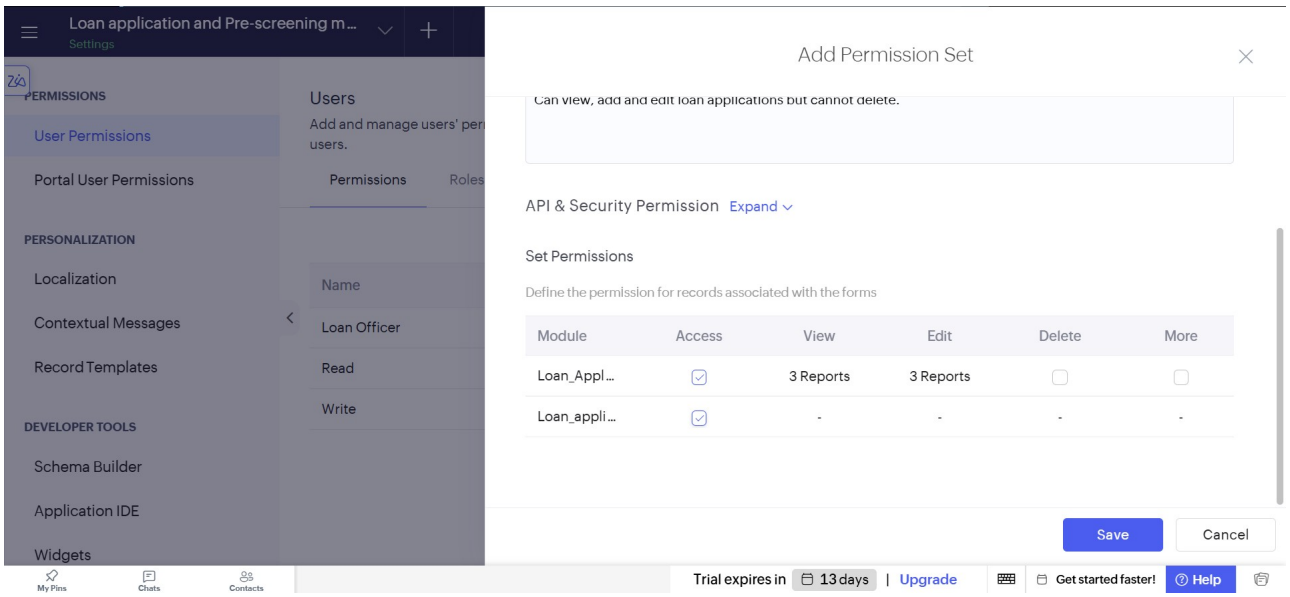


Fig. 3: Add Permission Set – Loan Manager (Access on both modules, View and Edit on the form's 3 reports, Delete and More unticked)

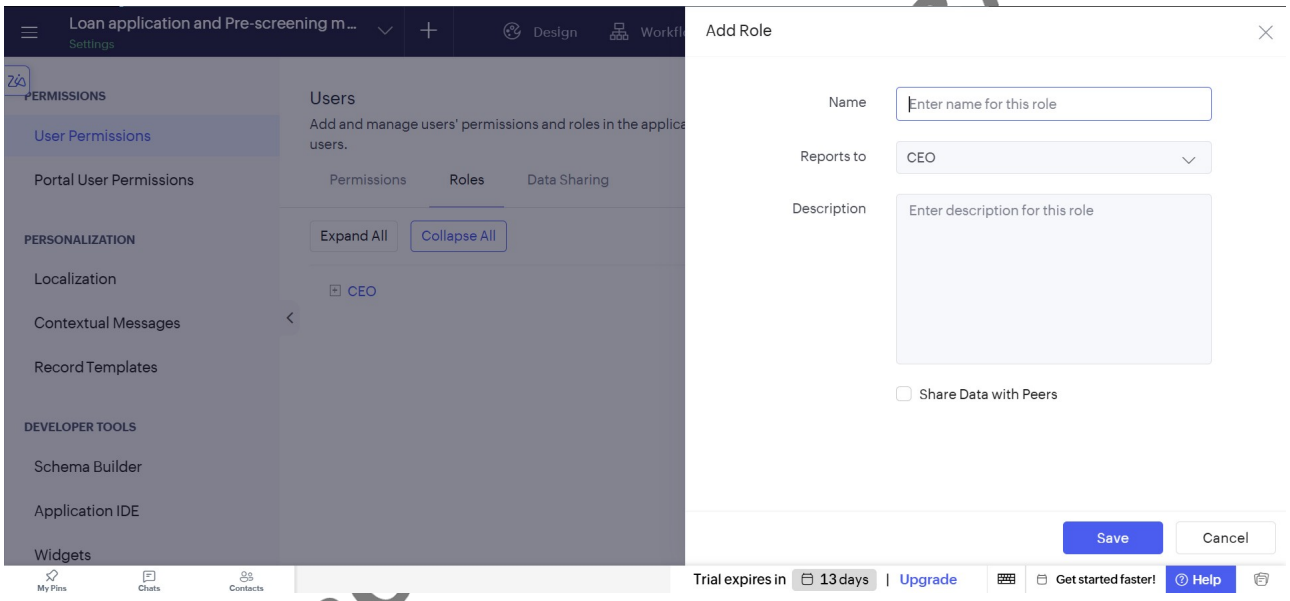


Fig. 4: Add Role dialog – name, Reports to and description

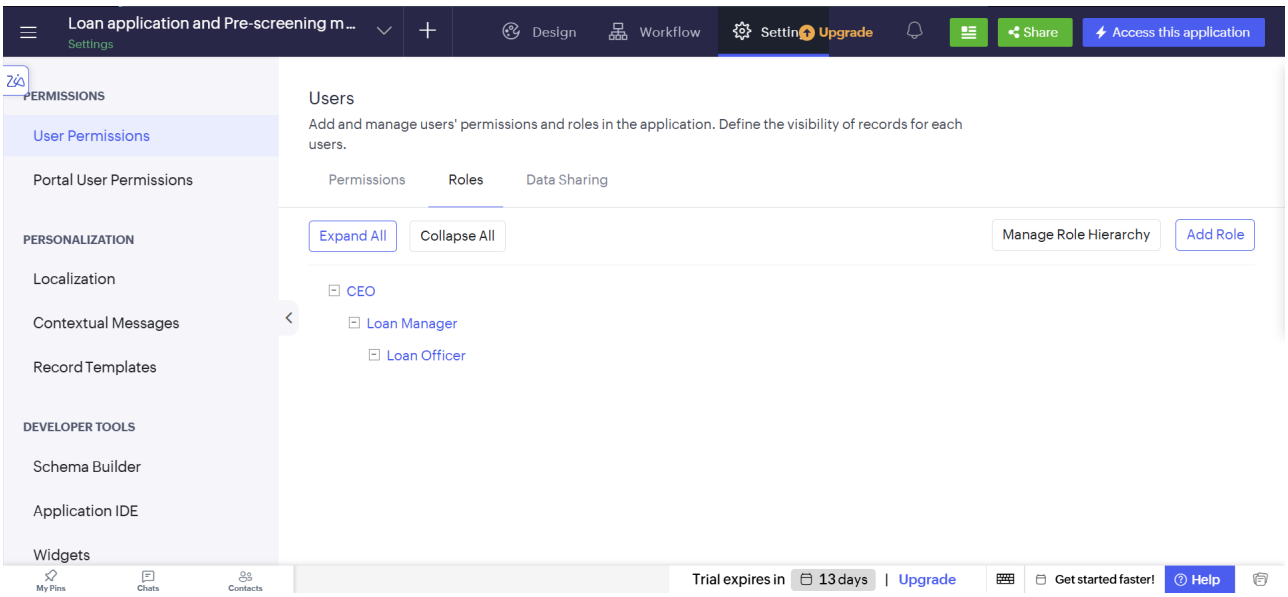


Fig. 5: Role hierarchy CEO → Loan Manager → Loan Officer

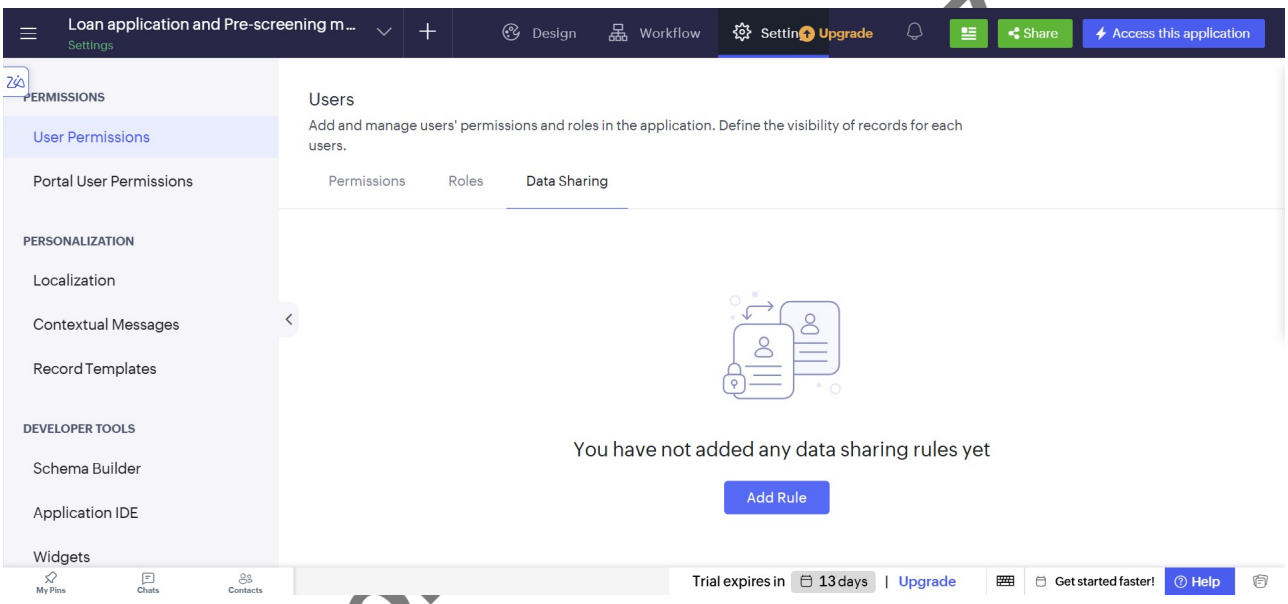


Fig. 6: Data Sharing tab – no rules saved

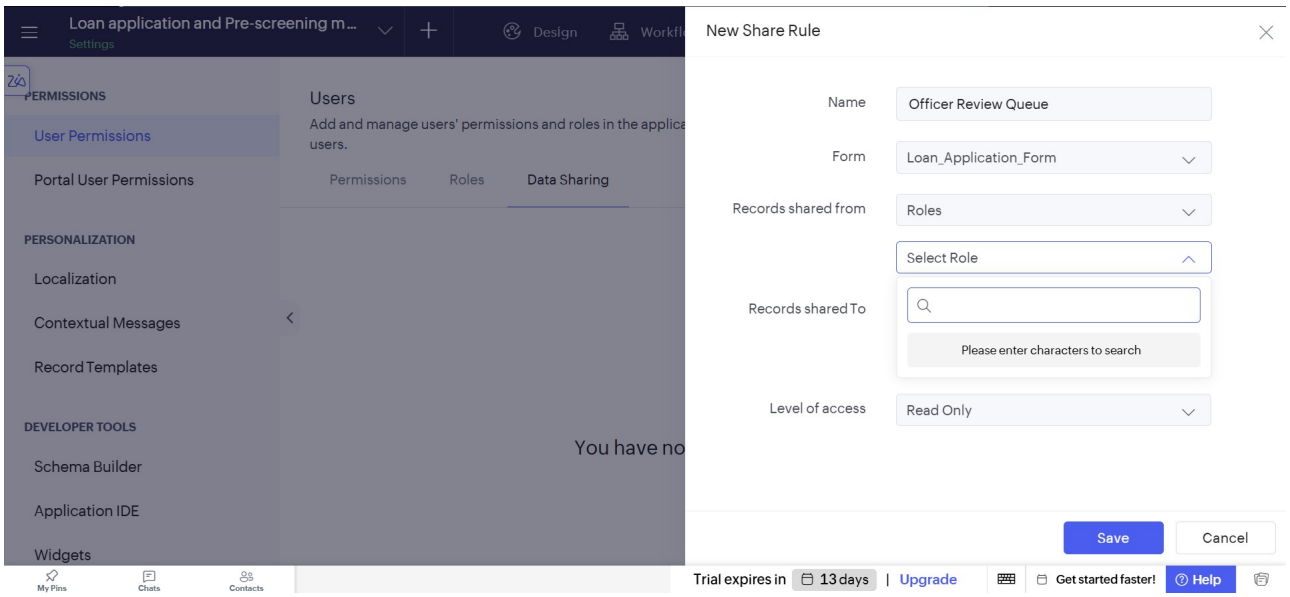


Fig. 7: New Share Rule dialog – Officer Review Queue on Loan_Application_Form (Read Only)

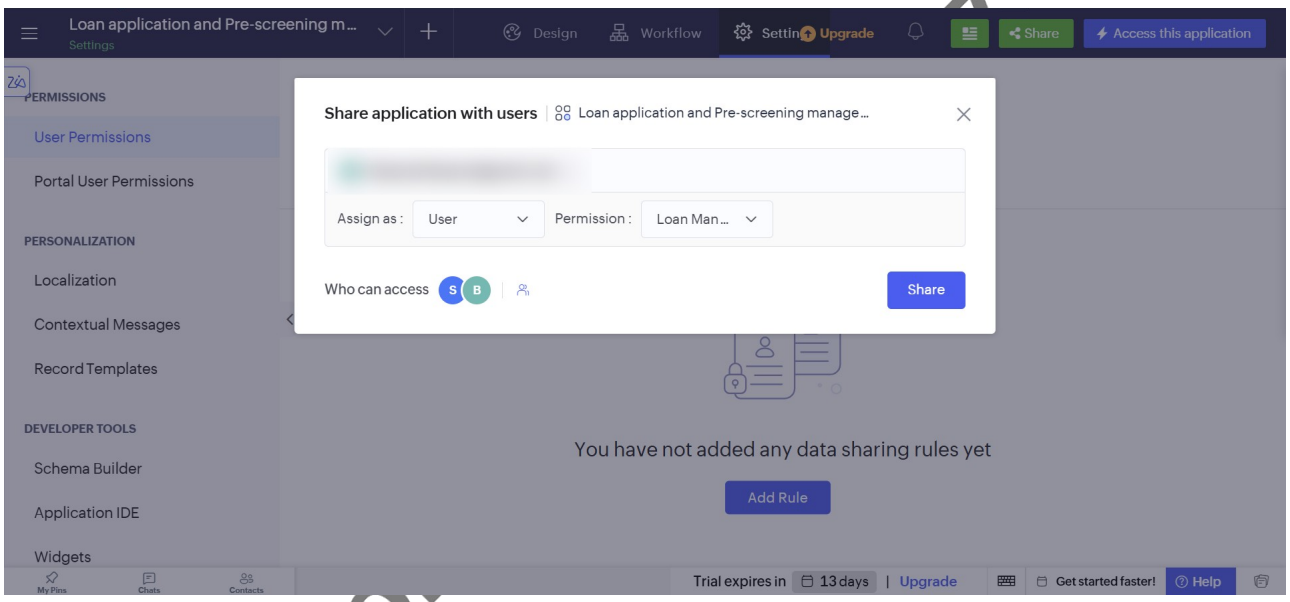


Fig. 8: Share application with users – Assign as User with a permission set (e-mail blurred)

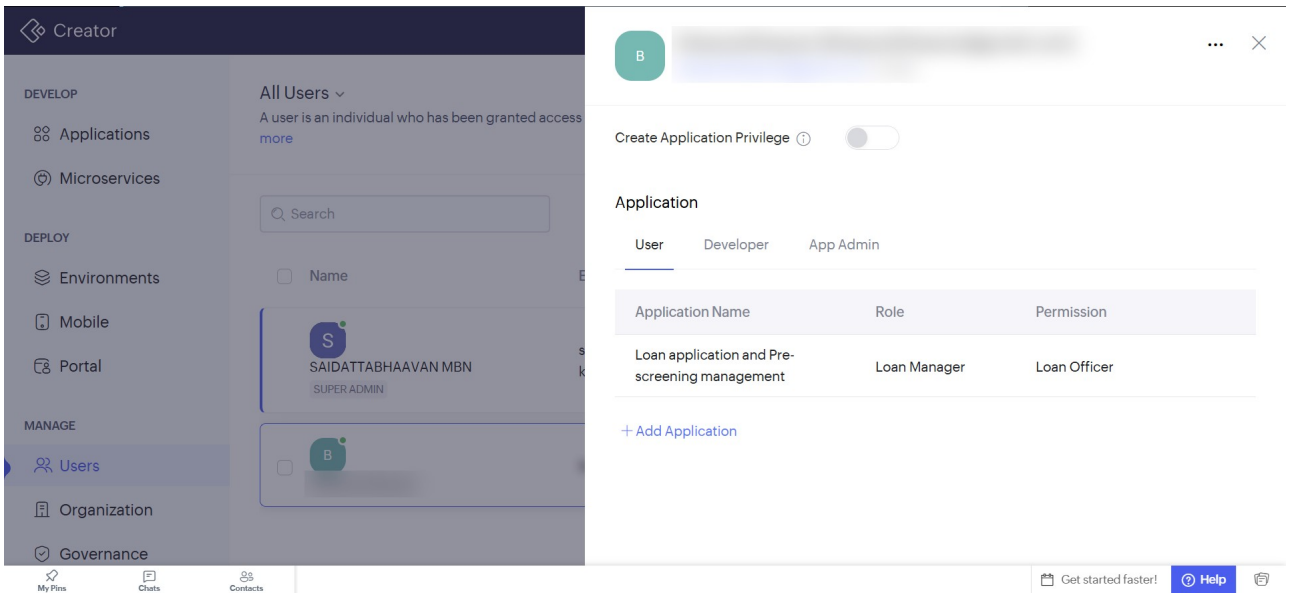


Fig. 9: Users page – invited user's detail panel showing the application with its Role and Permission (details blurred)

RESULT

Role-based access control was set up in the Loan Application and Pre-screening Management app. Two custom permission sets (Loan Officer and Loan Manager) were created beside the default Read and Write sets, a three-level role hierarchy (CEO, Loan Manager, Loan Officer) was built, and a user was invited and shared into the application with a role and permission. The data sharing rule was designed but not saved because of a loading problem in the trial interface, and the invited user's sign-in was not tested. Thus user management and role-based access control in Zoho Creator were successfully studied and configured.

Conclusion

Combining permission sets, a role hierarchy and data sharing rules lets a Zoho Creator application protect sensitive records without any code. For the loan application this means front-line officers can capture applications, managers can review and correct them, and only the administrator can delete them, which is the least-privilege model expected of a financial application.

ROLL NO: 24140101087